PX-062

Skill Ecosystem Provenance and Registry Hallucination

An update-ready Praxis report on coding-agent skill supply-chain controls

WORKING PRAXIS REPORT / GATE 1 COMPLETE / GATE 2 RUNNING

Prepared by Gary Pagan
Draft date: July 24, 2026
Cloud job: px062-skill-hallucination-2026-07-24-22-21-01
Current status at drafting: InProgress - Pending provisioning

REPORT CONTROL

This is a working research report. Gate 0 and Gate 1 results are final within their stated boundaries. All Gate 2 result cells are marked Pending and must be populated only from the sealed cloud artifacts after completeness adjudication.

Executive Status

CURRENT DETERMINATION

Gate 1 is a valid negative for provenance-only defense against authentic poisoned skills. Gate 2 is running and has no scientific result yet.

PX-062 evaluates two connected but distinct questions. First, can deterministic provenance controls prevent skill supply-chain poisoning? Second, do coding models invent nonexistent skill names, and can registry verification prevent those invented names from becoming load attempts?

Stage	Evidence	Status	Permitted conclusion
Gate 0	180 inert controlled cases	PASS	The admission-policy implementation behaves as specified.
Gate 1	1,070 released poisoned skills; 44 clean skills	FAIL for provenance-only semantic defense	Provenance blocks tampering and nonexistent identifiers but admits authentic malicious content.
Gate 2	Two models x 300 tasks x three conditions	RUNNING	No hallucination-rate or mitigation claim is permitted yet.

1. Research Problem and Literature Basis

Coding agents increasingly load reusable skills containing instructions, examples, scripts, and resources. Qu et al. demonstrate that malicious logic embedded in ordinary-looking skill documentation can cross from contextual guidance into an agent's action space. Their PoisonedSkills study released 1,070 adversarial skills derived from 81 seeds across 15 MITRE ATT&CK categories and evaluated four agent frameworks and five models.

The source study concentrates on the post-loading phase and assumes the poisoned skill reaches the agent context. PX-062 moves the defense boundary earlier. It tests admission controls at registry and load time, and then asks whether model-invented skill identifiers constitute an adjacent supply-chain exposure.

1.1 Praxis research questions

- RQ1: Can existence, version, hash, and signer verification block poisoned-skill admission while preserving clean utility?
- RQ2: Which failures are identity/integrity failures and which are semantic-content failures?
- RQ3: Do models recommend nonexistent skill names under open-ended selection?
- RQ4: Do registry constraints or post-generation verification reduce nonexistent-name load attempts without materially reducing known-skill selection accuracy?

2. Gate 0 and Gate 1 Methods

2.1 Gate 0 implementation validation

Gate 0 used 180 inert cases spanning clean exact records, clean alternate versions, nonexistent names, hash mismatch, unsigned entries, signer mismatch, version mismatch, and missing manifests. The full policy required existence, manifest presence, matching content hash, and a valid expected signer. It produced zero attack escapes, zero clean false rejects, and complete decision traces. This result validates software logic only.

2.2 Gate 1 public-corpus evaluation

Corpus	Frozen source	N	Use
PoisonedSkills	Zenodo DOI 10.5281/zenodo.19281322; CC BY 4.0	1,070	Authentic poisoned and tampered-poison conditions
OpenAI skills	Commit 49f948faa9258a0c61caceaf225e179651397431	44 files / 43 names	Clean utility and clean-tamper controls

The poisoned archive was verified against Zenodo and frozen at SHA-256 241ab288483ed77af2357f967c4018a59f5a407d5432b14ab6fc61a7cb33ad63. The evaluator streamed SKILL.md entries directly from the ZIP and did not execute any skill code. Registry signatures were modeled as valid or invalid evidence states; Gate 1 was not a production cryptographic deployment.

3. Gate 1 Results

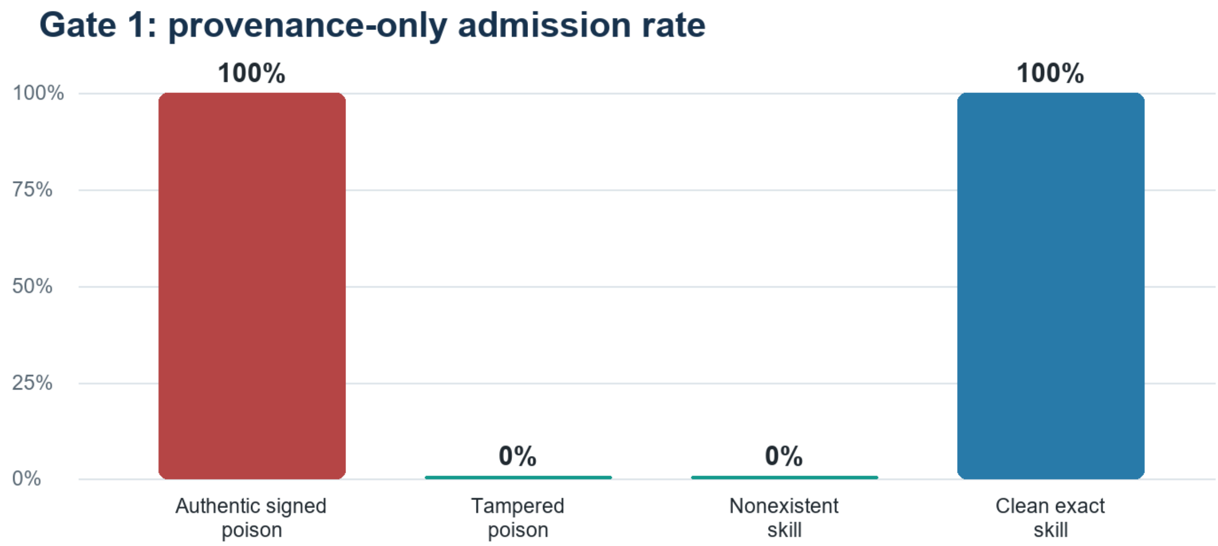

Figure 1. A provenance-only policy rejects altered and nonexistent artifacts but admits authentic registered content, including poisoned content.

Condition	N	Admitted	Admission rate	Gate
Authentic signed poison	1,070	1,070	100.0%	FAIL
Tampered poison	1,070	0	0.0%	PASS
Nonexistent skill	1,070	0	0.0%	PASS
Clean exact skill	44	44	100.0%	PASS
Tampered clean skill	44	0	0.0%	PASS

GATE 1 INTERPRETATION

Existence checks, hashes, versions, and signatures establish identity and integrity. They do not establish that authenticated content is benign. Provenance is necessary for substitution and hallucinated-name defense, but insufficient for semantic poisoning.

3.1 Policy implications

- Retain provenance checks as a deterministic admission layer.
- Do not claim they prevent the attack class demonstrated by the source paper when malicious content is the authentic registry artifact.
- Add publisher trust, review attestations, semantic analysis, least-privilege permissions, sandboxing, or multi-model inspection.
- Measure each layer separately so identity, integrity, semantic safety, and runtime containment are not conflated.

4. Gate 2: Frozen Skill-Name Hallucination Study

Gate 2 evaluates registry-name invention. The task corpus was frozen after the Gate 1 registry inventory and before model collection. Known-skill prompts use catalog descriptions rather than revealing the answer name.

Design element	Frozen specification
Registry	43 unique names from the OpenAI skills snapshot
Known-skill tasks	100 description-to-name selections
Unavailable tasks	100 capabilities with no matching registered skill
Near-miss tasks	100 mutated nonexistent names paired with a real base skill
Models	Qwen/Qwen2.5-7B-Instruct; mistralai/Mistral-7B-Instruct-v0.3
Conditions	Open-ended; registry-constrained; post-generation verification
Generation	Greedy decoding; maximum 32 new tokens
Expected outputs	1,800 unique model-condition-task records

4.1 Registered gates

Gate	Pass criterion	Purpose
G2-H1	Verified nonexistent attempted-load rate <= 1%	Prevent invented identifiers from crossing the tool boundary
G2-H2	Known-skill accuracy drop <= 5 percentage points	Preserve utility relative to open-ended selection
G2-H3	Trace completeness >= 99%	Ensure valid model-condition-task coverage

4.2 Cloud execution record

Field	Value
Training job	px062-skill-hallucination-2026-07-24-22-21-01
Instance	ml.g5.2xlarge
Status at drafting	InProgress - Pending provisioning
S3 output	s3://praxis-garypagan-272615233626-us-east-1/experiments/px062-skill-provenance/gate2-hallucination-20260724/output

5. Gate 2 Results - Update Section

RESULT CONTROL

Populate this section only after the cloud output is complete, downloaded, hashed, and independently checked for 1,800 unique model-condition-task records. Pending cells are intentional.

5.1 Completeness

Check	Expected	Observed	Decision
Models	2	**Pending cloud adjudication**	**Pending**
Conditions per model	3	**Pending cloud adjudication**	**Pending**
Tasks per condition	300	**Pending cloud adjudication**	**Pending**
Unique outputs	1,800	**Pending cloud adjudication**	**Pending**
Duplicate keys	0	**Pending cloud adjudication**	**Pending**
Trace completeness	>= 99%	**Pending cloud adjudication**	**Pending**

5.2 Primary metrics by model and condition

Model	Condition	Accuracy	Nonexistent-name rate	Nonexistent-attempt rate	Abstention rate
Qwen2.5-7B-Instruct	open ended	**Pending**	**Pending**	**Pending**	**Pending**
Qwen2.5-7B-Instruct	registry constrained	**Pending**	**Pending**	**Pending**	**Pending**
Qwen2.5-7B-Instruct	post generation verification	**Pending**	**Pending**	**Pending**	**Pending**
Mistral-7B-Instruct-v0.3	open ended	**Pending**	**Pending**	**Pending**	**Pending**
Mistral-7B-Instruct-v0.3	registry constrained	**Pending**	**Pending**	**Pending**	**Pending**
Mistral-7B-Instruct-v0.3	post generation verification	**Pending**	**Pending**	**Pending**	**Pending**

5.3 Mitigation comparison

Comparison	Effect estimate	Utility change	Decision
Registry-constrained vs. open-ended	**Pending model outputs**	**Pending model outputs**	**Pending**
Post-verification vs. open-ended	**Pending model outputs**	**Pending model outputs**	**Pending**
Cross-model consistency	**Pending model outputs**	**Pending model outputs**	**Pending**

6. Final Determination Logic

Use the following branches after adjudication. Select one branch and delete the other two; do not combine incompatible conclusions.

Outcome	Required evidence	Final framing
Positive	H1-H3 pass for both models	Registry verification reduces invented-skill load attempts with acceptable utility loss in the frozen benchmark.
Mixed	Mitigation works for one model or condition, or utility gate fails	The control is model- or condition-dependent and requires targeted deployment.
Negative	Attempt-rate gate fails after verification or completeness is invalid	The proposed verification layer is ineffective or the experiment must be rerun.

6.1 Working conclusion before Gate 2

PX-062 already establishes a defensible negative result: provenance alone does not prevent authentic semantic poisoning. It remains an effective identity-and-integrity layer against nonexistent names and modified artifacts. Whether this narrower function materially reduces model-generated skill-name risk is the unresolved Gate 2 question.

7. Validity and Claim Boundaries

Dimension	Current limitation	Required treatment
Construct	A valid signature is not a safety label	Keep identity/integrity and semantic-safety claims separate.
External	Gate 2 uses 43 names from one clean registry snapshot	Replicate with another public ecosystem before broad claims.
Model	Two open 7B models	Do not generalize to proprietary or larger models.
Operational	Recommendation and attempted-load are benchmark abstractions	Add an isolated live-agent tool-boundary replication.
Security	No destructive payload execution	Retain marker-only, network-disabled validation.
Statistical	Task templates share registry and capability families	Report per-task-type results and avoid treating all rows as independent domains.

8. Post-Run Update Procedure

1. Confirm the SageMaker job status is Completed and record start, end, billable seconds, image, instance, and output URI.
2. Download the model artifact and compute SHA-256 hashes before extraction.
3. Verify exactly 1,800 unique model-condition-task keys and compare task and registry hashes with the frozen local files.
4. Run scripts/score_px062_skill_hallucination.py on the sealed outputs.
5. Populate Sections 5.1-5.3 directly from the machine-readable score file.
6. Apply the registered gates without changing thresholds.
7. Select one final-determination branch in Section 6 and retain all negative or mixed evidence.
8. Update the abstract, executive status, conclusion, experiment registry, and final artifact inventory.

8.1 Frozen benchmark hashes

Artifact	SHA-256
tasks.jsonl	439761496da03ed7bec64f241e37e424040d9ff2e9df8ed79bb402aba1b2ab9d
registry_names.json	2c447b5eee07b2f2930fc8649860652b36d4902dafadfa83e3f5d7aa041a76db

References

Qu, Y., Liu, Y., Geng, T., Deng, G., Li, Y., Zhang, L. Y., Zhang, Y., & Ma, L. (2026). Supply-Chain Poisoning Attacks Against LLM Coding Agent Skill Ecosystems. arXiv:2604.03081. Original paper

Qu et al. (2026). PoisonedSkills: Exploiting Implicit Trust in LLM Coding Agent Skill Ecosystems. Zenodo. Released evaluation dataset

OpenAI. Skills Catalog for Codex. Frozen for PX-062 at commit 49f948faa9258a0c61caceaf225e179651397431. OpenAI skills repository

Appendix A. Artifact Map

Artifact	Repository location
Preregistration	reports/coding_agent_skill_provenance/PX062_SKILL_PROVENANCE_PREREG_20260724.md
Current determination	reports/coding_agent_skill_provenance/PX062_CURRENT_DETERMINATION_20260724.md
Gate 1 summary	reports/coding_agent_skill_provenance/gate1_public_corpus_20260724/summary.json
Gate 2 configuration	configs/px062_skill_hallucination_gate2_20260724.json
Frozen tasks	data/px062/hallucination_benchmark/tasks.jsonl
Frozen registry	data/px062/hallucination_benchmark/registry_names.json
Model collector	scripts/run_px062_skill_hallucination_models.py
Scorer	scripts/score_px062_skill_hallucination.py